SECURITY NINJA GERMANY



About Tim

Focus

AD & Entra ID security
disaster recovery

Role

Senior Solution Architect
Semperis

Blog

azurehero.de



Background

Ex-Microsoft Premier Field Engineer
(Entra ID, Zero Trust)

Hobbies

Home Assistant
3D printing
drones

Contact

linkedin.com/in/tim-stock

SECURITY NINJA GERMANY

Raise your hand, if...

Hybrid!

SECURITY NINJA GERMANY

Raise your hand, if...

IGA!

SECURITY NINJA GERMANY

Raise your hand, if...

IGA tool connected to AD!

SECURITY NINJA GERMANY

Raise your hand, if...

AND to EID!

Modern Hybrid IGA

SECURITY NINJA GERMANY

Tech Deep Dive

Problem & building blocks

Target picture, access packages

Bridge to on-premises

Cloud Sync, writeback, SOA

Bridge between tenants

Cross-tenant sync, Tenant Governance

Workflows

GPO admin, Teams admin, one package

Security & takeaways

Cloud → Tier 0, hardening

Hybrid identity, split governance

SECURITY NINJA GERMANY

AD Active Directory

- GPO, OU and server admins via ticket and manual group changes
- Kerberos/LDAP apps check AD groups
- No expiry, no review, group sprawl
- Tier 0 lives here

A Home tenant

- Access packages, PIM, access reviews – governed
- But: stops at the tenant boundary
- And: stops at the AD boundary while groups are synced from AD

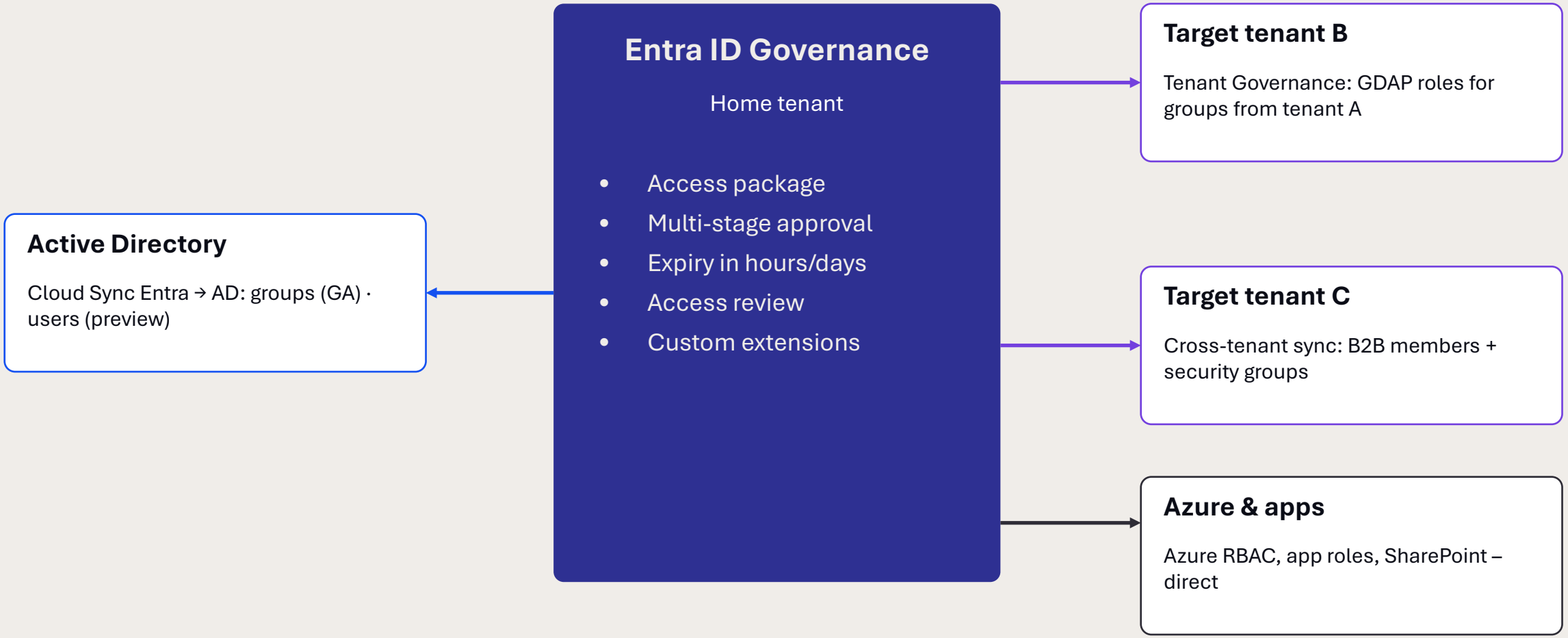
B Other tenants

- M&A, regions, test, shadow IT
- Local or B2B admin accounts per tenant
- Roles assigned separately in each tenant
- Central view? None

Result: three request paths, three audit trails – and no answer to “who can do what, where, and for how long?”

Target picture: one control plane

One request path · one policy · one audit trail – delivered into every world



01
Building blocks

Entitlement management in 2026 – more than groups and apps

Anatomy of an access package

SECURITY NINJA GERMANY

Catalog

Container + delegation boundary (catalog owner)

↓

Access package

Bundle of resource roles

↓

Policies

Who · approval · expiry · reviews · extensions

↓

Assignment

Granted to an identity, time-bound

Resource roles

Groups & Teams

Member / owner – with PIM for Groups also eligible member/owner

Applications

App roles (SAML/OIDC, provisioned apps, on-prem via ECMA)

SharePoint Online

Site roles

Microsoft Entra roles PREVIEW

Eligible or active; privileged roles eligible only – going forward only non-privileged roles

Azure RBAC

Management group, subscription, resource group · eligible or active

Policies & custom extensions

P Policy engine

- **Who:** users in the directory, connected organizations or any external user
- **Approval:** multi-stage, manager / sponsor / fixed approvers, justification
- **Lifecycle:** expiry by date, days or hours
- **Access reviews:** recurring, removal on deny
- **Separation of duties:** incompatible packages / groups
- **Externals:** B2B invitation on approval, account cleanup after the last assignment

X Custom extensions (Logic Apps)

- Stages: request created · approved · assignment granted · removed · 14 days / 1 day before expiry
- Launch and continue, or launch and wait (timeout ≤ 14 days)
- Dynamic approvers from external logic (e.g. HR, ITSM)

```
# Launch and wait: request waits for callback
POST /identityGovernance/entitlementManagement
  /assignmentRequests/{id}/resume

# Logic App (managed identity) needs in the catalog:
#   Access package assignment manager
```

SECURITY NINJA GERMANY

02
Bridge to on-premises

Microsoft Entra Cloud Sync: Microsoft Entra ID → Active Directory

Cloud Sync Entra ID → AD

SECURITY NINJA GERMANY

1 Scope

Scoping filter: selected groups, or all security groups + attribute filter

2 Match

Existing AD object? Anchor msDS-ExternalDirectoryObjectId, or SID after SOA

3 Map

Attribute mappings (direct / constant / expression), e.g. sAMAccountName

4 Write

Provisioning agent translates to LDAP operations – deltas only per cycle

What is generally available?

Groups only	Security groups + memberships	GA
Users only	User objects	PREVIEW
Users + groups	Both in one configuration	PREVIEW

Operations

- One configuration type: “Microsoft Entra ID to AD sync”
- Recurring cycle (30 min default) + provision on demand
- Global Entra tenants only (no B2C)
- Runs side by side with Connect Sync (AD → Entra)

Group writeback to AD

GA

- **Security groups only** – no mail-enabled groups, no DLs
- **Always universal** – anchor msDS-ExternalDirectoryObjectId
- **Members need an AD account:** synced users need onPremisesObjectIdentifier = objectGUID
- **Membership for on-prem users** is off by default – enable it in the scoping wizard
- **Names:** cn = displayName(51) + "_" + part of objectId; sAMAccountName is random → add a mapping
- **Default target:** CN=Users – set target container / OU via mapping
- **Connect Sync group writeback v2** is deprecated; M365 groups stay on v1

Scale limits

Scoping mode	Groups	Memberships
Selected security groups	≤ 10,000	≤ 250,000
All security groups + attribute filter	≤ 20,000	≤ 500,000

Not supported

- Groups > 50,000 members
- “All security groups” without an attribute filter
- The UI shows max. 999 groups → beyond that, use Graph appRoleAssignedTo on the job service principal

User writeback to AD

PREVIEW

User type	SOA	Result in AD
Cloud-native	Cloud	New AD account in the target container
SOA-converted	Cloud	Matched + updated in place, OU and SID kept
B2B guest	Cloud	AD account if in scope
Synced	On-prem	Not provisioned – AD stays authoritative

Lifecycle

- Soft delete / out of scope → AD account disabled
- Hard delete → AD account deleted
- Direct AD changes to managed attributes are overwritten

Written back to Entra

```
onPremisesDistinguishedName
onPremisesSamAccountName
onPremisesSecurityIdentifier
onPremisesUserPrincipalName
onPremisesDomainName
```

No AD password

- No password writeback for cloud-managed users
- Apps needing an AD password (LDAP bind): not supported
- Kerberos passwordless: WHfB cloud Kerberos trust or FIDO2

Source of authority for groups

1 AD group

synced via Connect/Cloud Sync, the app uses its SID

2 Switch SOA

isCloudManaged = true · sync clients stop the object

3 Group is cloud object

membership via access package / review

4 Back to AD

Cloud Sync matches by SID → updates the original group

```
PATCH https://graph.microsoft.com/v1.0
      /groups/{id}/onPremisesSyncBehavior
{ "isCloudManaged": true }

# Audit: "Change Source of Authority from AD to cloud"
```

- Connect Sync sets blockOnPremisesSync – AD changes no longer flow (event 6956)
- Convert groups before users
- Rollback possible: AD takes over in the next cycle

! Keep OU and CN

- Change the AD group scope to universal first
- Create directory extension GroupDN on app CloudSyncCustomExtensionsApp
- Map distinguishedName into it, verify, then switch SOA
- Expressions for cn and parentDistinguishedName
- AD Recycle Bin enabled – restore with the same SID

Deep dive: AD object enforcement

PREVIEW

1 LDAP write

Admin changes a group / user (ADUC, PowerShell, LDAP)

→

2 Marked?

msDS-ObjectSoa = Cloud on the object (set via Cloud Sync mapping)

→

3 SID allowed?

SOA policy in CN=SOA-Policies, CN=System – list of allowed SIDs

→ **Yes → commit**

→ **No → block (enforced) / event (audit)**

Prerequisites

- Every writable DC: Windows Server 2022/2025 + update + GPO package
- No functional level required; attribute exists since schema 2016
- Install policy with Set-CloudSyncSOAPolicy.ps1 (Domain Admin, remove afterwards)
- Break glass: additional SID in the policy

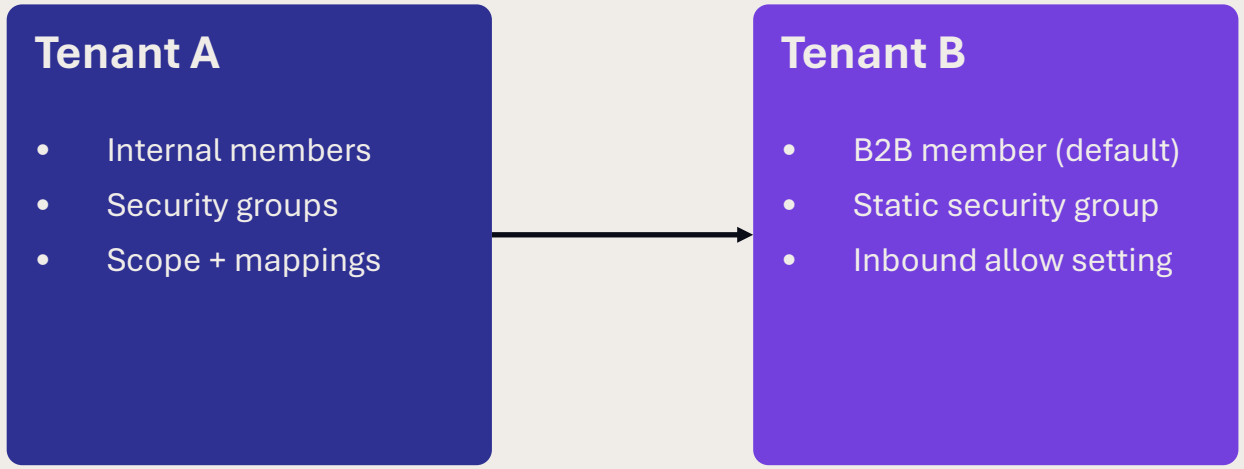
! Preview limits

- Deletions are not prevented
- LDAP add still allowed; nesting into unprotected groups too
- One DC without the feature = bypass for every object
- Switching SOA alone doesn't lock the AD object

03
Bridge between tenants

Cross-tenant synchronization and Microsoft Entra Tenant Governance

Cross-tenant sync: users and groups



- **License:** user sync Entra ID P1 · group sync Entra ID Governance / Suite
- **Matching:** alternativeSecurityIds – can't be changed
- **Internal members only** from the source – no guests, no loops
- **Target admin** can stop the sync at any time

! Group restrictions

- Target is always a static security group
- Not role-assignable
- No nested groups
- Scope must be “Sync only assigned users and groups”
- Changes in the target persist until the source changes

Consequence: a synced group can't hold an Entra role in tenant B. Admin rights need a different path.

Microsoft Entra Tenant Governance

GA · AUGUST 2026

Complements multitenant organizations: MTO = end-user collaboration · Tenant Governance = admin access, discovery, configuration

1 Related tenants

- Discovery signals: B2B, multitenant apps, shared billing accounts
- Finds shadow IT tenants too
- License: Entra ID Governance

2 Governance relationships

- Cross-tenant delegated administration based on GDAP
- Policy templates with roles + groups
- Multitenant app injection

3 Configuration mgmt

- Baselines as JSON, snapshots
- 200+ resource types in Entra, Intune, Exchange Online, Teams, Purview, Defender
- Monitor every 6 h, drift report

4 Secure tenant creation

- New add-on tenants governed automatically (default template)
- Billing asset “Entra ID Free” as inventory and recovery anchor

Governance relationship under the hood

Handshake

1 Invitation

governed → governing · valid 30 days · skipped with a shared billing account

2 Governance request

governing → governed · with policy template · valid 14 days

3 Accept

governed reviews roles and apps → relationship + cross-tenant access settings

What happens technically

- **Template:** Entra built-in roles → role-assignable security group in the governing tenant
- **Group proxies** (remote tenant groups) in the governed tenant hold the GDAP roles
- **Membership** is managed in the governing tenant – this is where the access package plugs in
- **Snapshot:** template changes apply only after a new request + accept
- **Workload RBAC** (Azure, Defender) is granted to the proxy separately by the governed tenant

Limit / model	Value
Role assignments / apps per template	10 / 10
One-to-many · many-to-one	supported
Multi-tier · coexistence with Partner Center GDAP	not supported

Cross-tenant admin: 3 patterns

	Tenant Governance (GDAP)	B2B admin (cross-tenant sync + access package in target)	Local admin accounts
Account in target tenant	none – home credentials	B2B member per tenant	own account per tenant
Who controls the role?	Group membership in the governing tenant	Access package / PIM in the target tenant	manually in the target tenant
Governed where	central (home)	decentral (resource)	nowhere
Status	GA	Entra roles in APs: preview	–
Catch	not every admin portal supports GDAP	tenant limit per user, roles per tenant	credential overhead, orphaned accounts

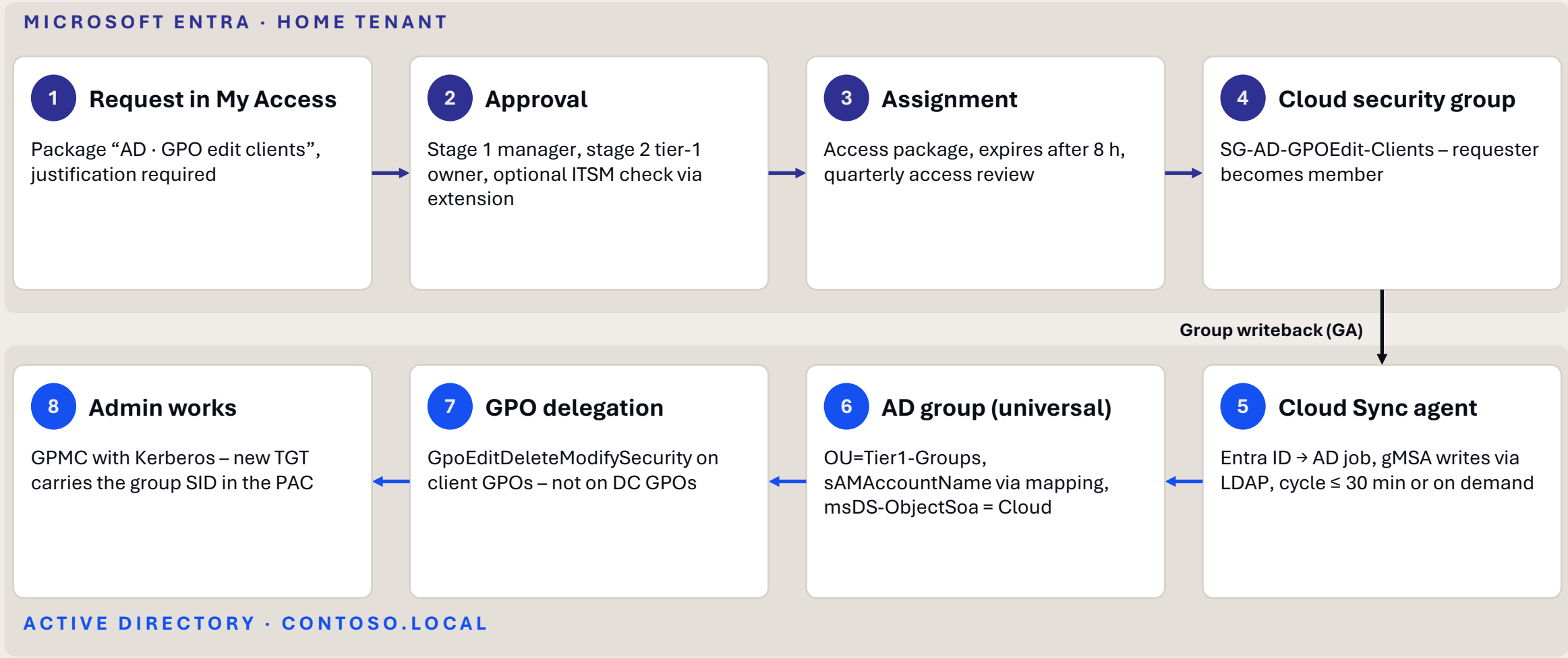
Whatever the pattern, the target tenant's Conditional Access and audit logs apply.

SECURITY NINJA GERMANY

04
Workflows

From request to permission – step by step

Workflow 1: GPO admin in AD



Revocation: expiry → removed from cloud group → next cycle → removed from AD group → effective with the next TGT

SECURITY NINJA GERMANY

Its Demo Time!

Workflow 1: pitfalls

1 Scope & nesting

- Provisioned groups are universal
- Universal can't be nested into global groups – e.g. Group Policy Creator Owners
- → set the GPO ACL directly or nest into domain local (AGDLP)

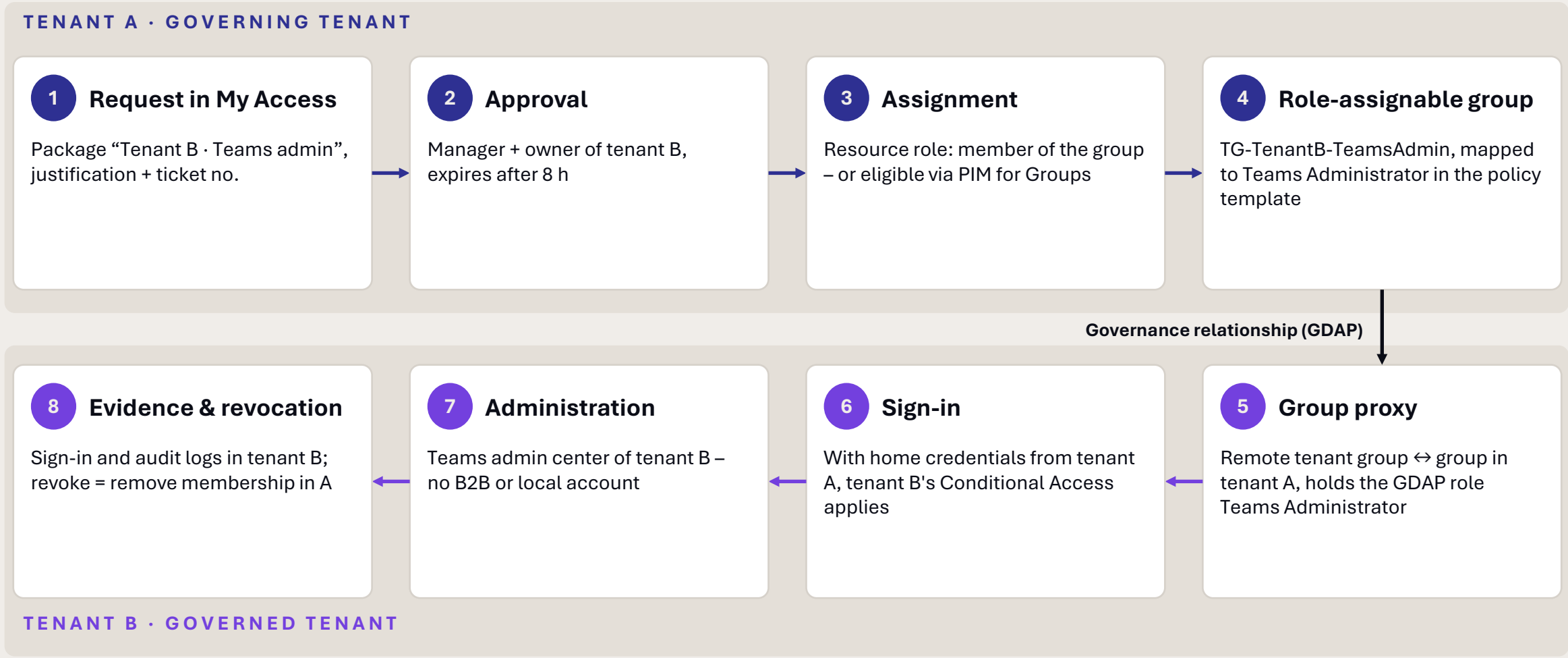
2 Timing & tokens

- Sync cycle 30 min by default
- Group SIDs live in the TGT's PAC
- TGT lifetime 10 h by default → revocation only after renewal (klist purge, sign-out)
- Expiry ≠ instant revocation

3 Who is the admin?

- Synced user: needs onPremisesObjectIdentifier
- Cloud-only: user writeback (preview) + WHfB / FIDO2
- No AD account: member is skipped

Workflow 2: Teams admin in tenant B



No sync job in between: the group in tenant A IS the permission in tenant B

SECURITY NINJA GERMANY

Demo again!

Workflow 2: design decisions

SECURITY NINJA GERMANY

! Role-assignable = privileged

- Adding the group to a catalog needs the right Entra and EM role
- Afterwards catalog owners, Identity Governance Admins and Global Admins control membership
- → dedicated catalog for tenant B admin packages only

P Combine with PIM for Groups

- Access package grants eligible member
- “Sign in to tenant” pane shows Activate for eligible members
- AP expiry ≤ “Expire eligible assignments after” of the group

T Template lifecycle

- A new role in the template applies only after a new request + accept
- Max. 10 role assignments per template
- One group per target role = one access package

? Test first

- Not every admin portal supports GDAP
- Workload roles (Azure, Defender) granted to the proxy separately
- Check tenant B's Conditional Access for delegated admins

Workflow 3: B2B admin in target tenant

SECURITY NINJA GERMANY

TENANT A

1 Scope group

Admin in group SG-Sync-to-TenantB

→

TENANT A

2 Cross-tenant sync

Push every 40 min, user as B2B member

→

TENANT B

3 B2B account

Admin exists in tenant B, auto-redemption

→

TENANT B PREVIEW

4 Access package (B)

Resource: Entra role Teams Administrator, eligible

→

TENANT B

5 PIM activation

Just in time in tenant B, MFA / CA of B

+ Pros

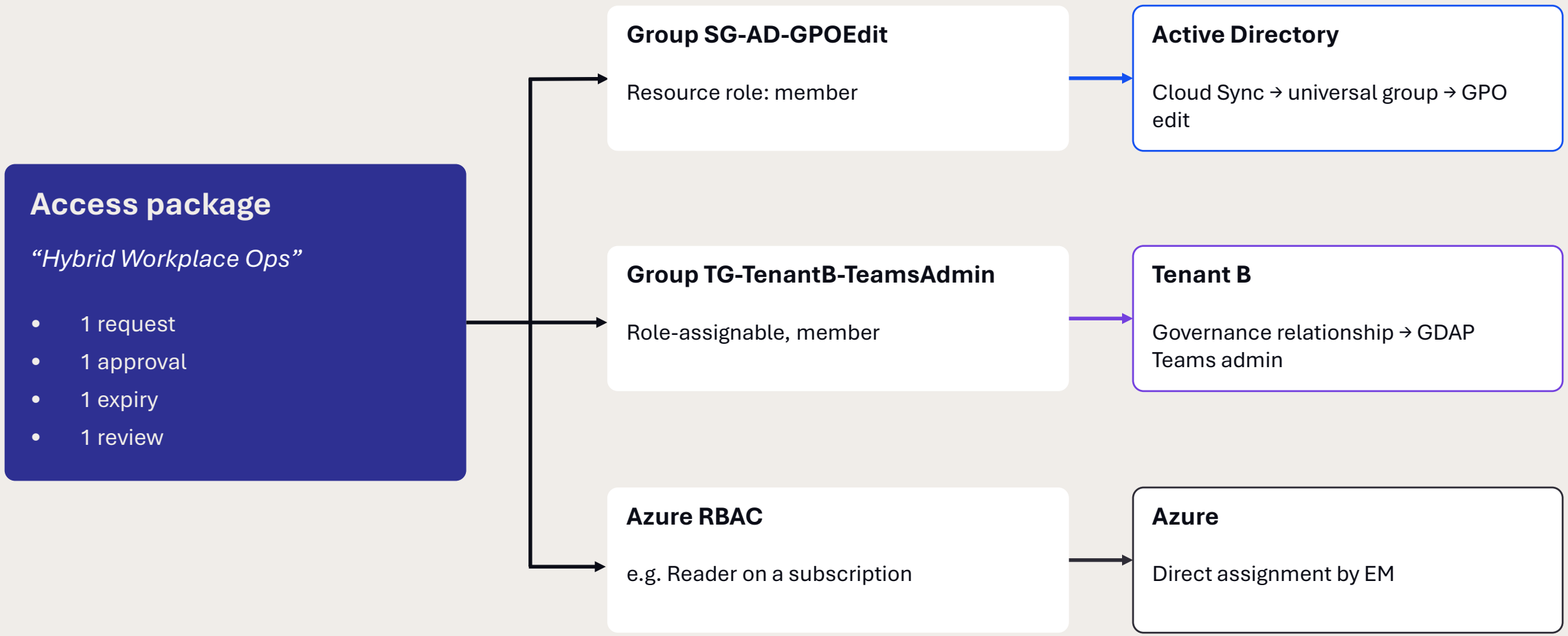
- Resource tenant decides itself (owner B approves)
- Native PIM just-in-time in the target tenant
- Across organizations too: connected organization instead of sync
- Works where admin portals don't support GDAP

– Cons

- One B2B account per tenant, tenant limit per user
- Entra roles in APs = preview, going forward non-privileged roles only
- Role governance spread across every tenant
- Synced group is not role-assignable

And again Demo!

One package, three worlds



Revoked in one place – with different latency: Azure immediately · tenant B on token renewal · AD after sync cycle + new TGT

05
Security view

The cloud becomes part of Tier 0

The new path: cloud → Tier 0

SECURITY NINJA GERMANY

1 Account compromised

Catalog owner, assignment manager, Groups Admin

2 Self-assignment

Direct assignment without approval, or edit the group directly

3 Cloud Sync writes

The AD group gets the account – via the legitimate path

4 Tier 0 impact

GPO edit on DC GPOs = code execution on DCs

What this means

- Whoever owns the catalog owns the AD permission
- The Cloud Sync agent host is Tier 0 – its gMSA writes groups
- Hybrid Identity Admin can set onPremisesDistinguishedName = move objects
- Role-assignable groups in a catalog = role assignment in tenant B

And the other way round

- Without enforcement an AD admin changes the group directly – governance bypassed until the next cycle
- Deletion still works with enforcement (preview)
- A single DC without enforcement is enough for a bypass

Hardening checklist

1 Delegation

- Separate catalogs per tier
- Catalog owners only from the matching tier
- Restricted management AUs for sensitive groups

2 Policy

- Multi-stage approval with justification
- Short expiry (hours)
- Access reviews, restrict direct assignment

3 Privileges

- PIM for Groups: eligible instead of permanent
- Privileged Entra roles only via PIM
- Separation of duties between packages

4 AD side

- Enforcement in enforced mode on all writable DCs
- Break-glass SID documented
- Treat the agent host like a DC

5 Monitoring

- Provisioning logs, audit “Change Source of Authority”
- Directory Service events (audit mode)
- Sign-in logs in tenant B, drift monitors

6 Recovery

- AD Recycle Bin enabled (restore with SID)
- SOA rollback tested
- Backups for AD and Entra – isolated from the production path

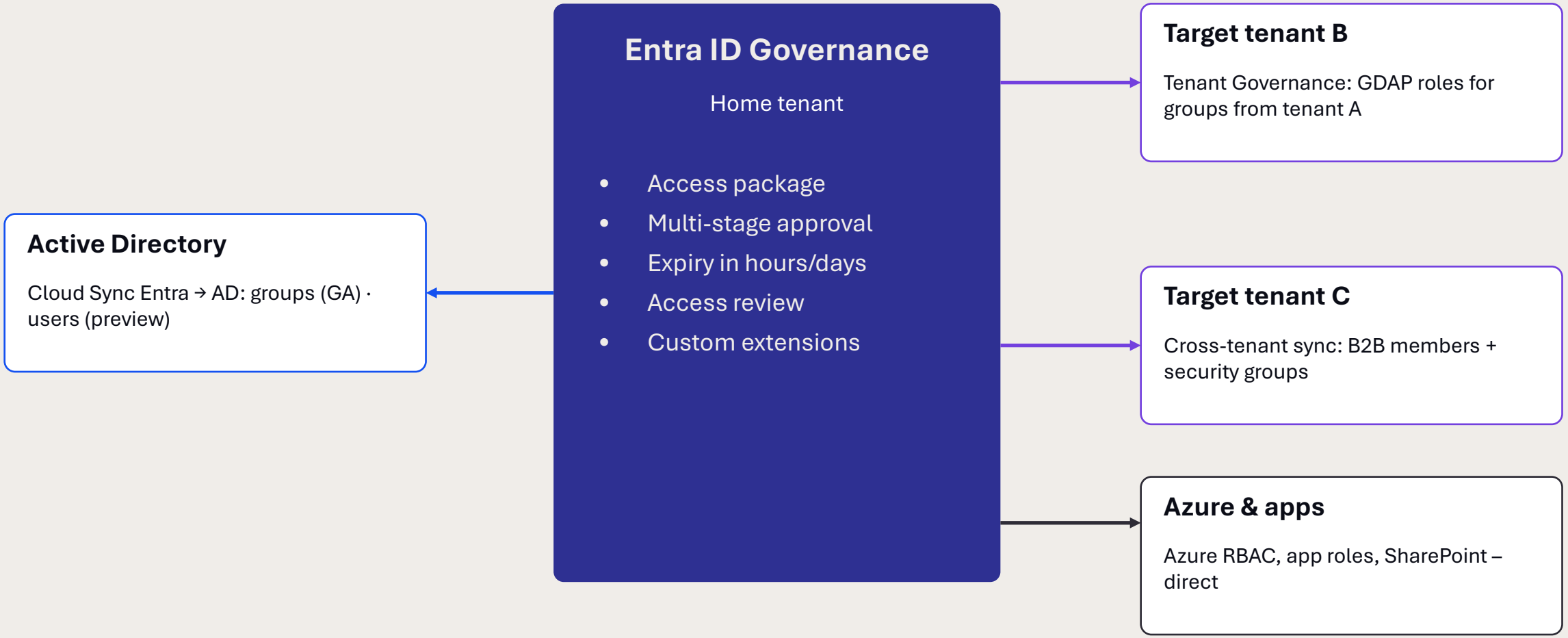
Takeaways

SECURITY NINJA GERMANY

1. Access packages are the control plane – delivery happens via groups, roles and GDAP
2. Groups to AD: GA. Users to AD: preview – and plan for passwordless
3. Tenant Governance (GA) replaces B2B and local admin accounts with group-based GDAP
4. Know your latency: sync cycle, TGT, tokens – expiry is not instant revocation
5. The cloud becomes part of Tier 0: protect catalogs, the agent host and enforcement accordingly

Final picture: one control plane

One request path · one policy · one audit trail – delivered into every world



Resources

SECURITY NINJA GERMANY

[Provisioning Entra ID → AD (overview)]

[How provisioning to AD works]

[AD user & group enforcement (preview)]

[Group writeback in entitlement management]

[Group source of authority]

[Entra roles in access packages (preview)]

[Cross-tenant synchronization]

[Tenant Governance overview]

[Cross-tenant delegated administration]

[Tenant estate guidance: admin patterns]

Questions?

Tim · Semperis

Thank you to our Sponsors!

Host Partner

Microsoft

Gold

glueck kanja

water IT Security & Defense

robopack

PROACT

Silver

WORKSIMPLE EINFACH ARBEITEN

semperis

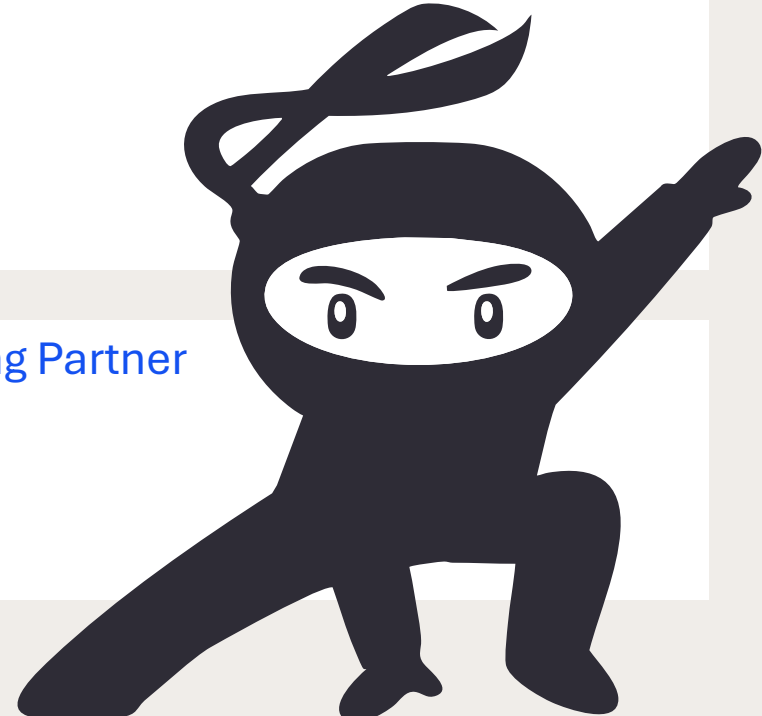
Bronze

ugurlabs

iC CONSULT

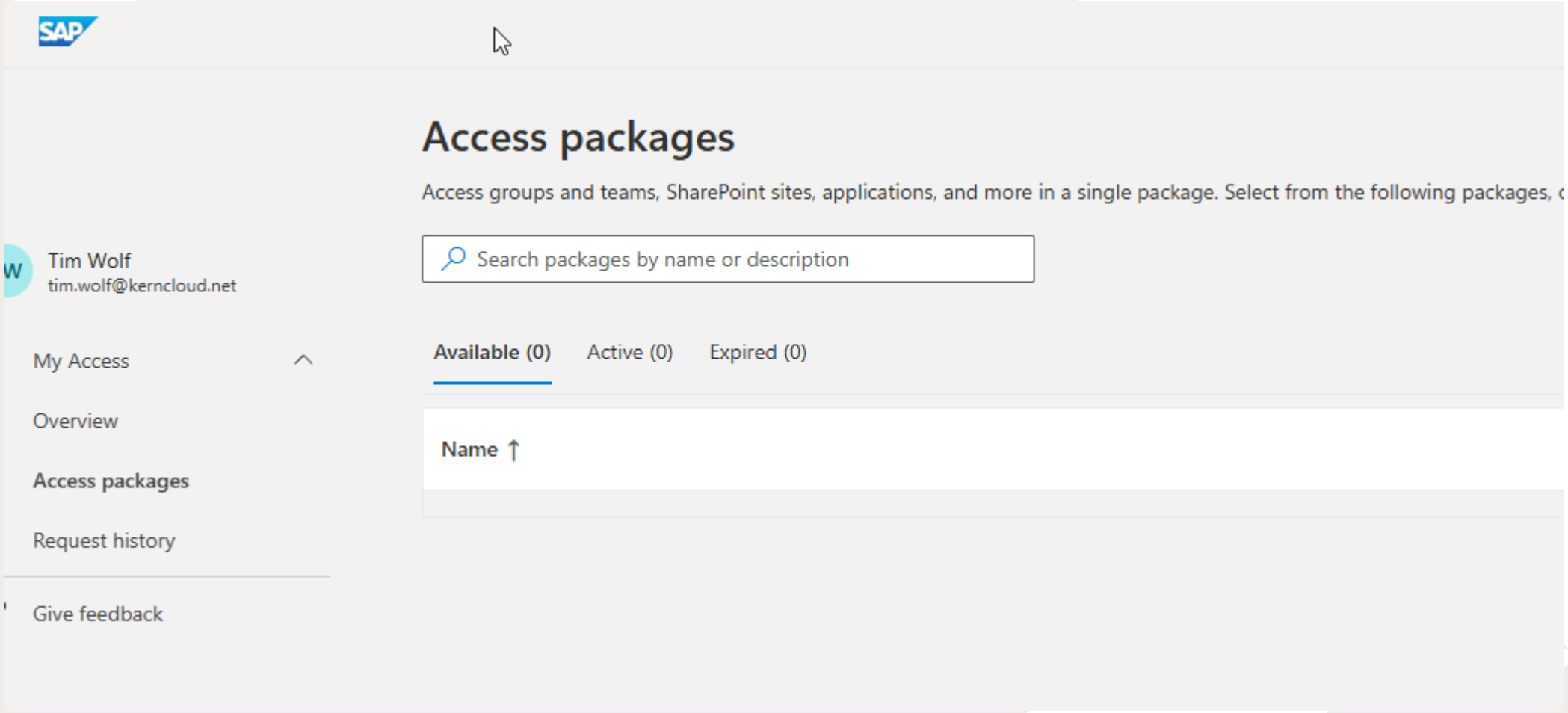
Snacks & Networking Partner

SCE



Thank You, Ninjas!




Access packages
Access groups and teams, SharePoint sites, applications, and more in a single package. Select from the following packages,
Tim Wolf
tim.wolf@kerncloud.net
Search packages by name or description
My Access
Overview
Access packages
Request history
Give feedback
Available (0)
Active (0)
Expired (0)
Name